PQC DAILY STUDY SERIES

Deep Dive: ML-DSA for Secure Firmware and Over-the-Air (OTA) Updates

Day 33 | Category: Software Supply Chain and Firmware Security Date: 2026-10-17 | DAILY MONITORING

Deep Dive: ML-DSA for Secure Firmware and Over-the-Air (OTA) Updates

As the Internet of Things (IoT) and embedded systems become ubiquitous, securing their software supply chain is more critical than ever. Firmware and Over-the-Air (OTA) updates are primary vectors for attacks. A compromised update mechanism can lead to widespread device takeover. The advent of quantum computing threatens traditional signature schemes like RSA and ECDSA, making the transition to a quantum-resistant solution like the Module-Lattice-based Digital Signature Algorithm (ML-DSA), standardized as FIPS 204, an immediate necessity.

Why ML-DSA is Crucial for Firmware Signing

Firmware signing ensures that only authentic and unaltered software from the manufacturer can be installed on a a device. ML-DSA provides the quantum-resistant assurance needed to maintain this trust in the long term, protecting against "Harvest Now, Decrypt Later" scenarios where attackers might store signed firmware today to break its signature with a future quantum computer.

- **Longevity:** Embedded devices can be in the field for decades. Their security must be future-proof against quantum adversaries.
- **High Security Assurance:** ML-DSA is built on well-studied mathematical problems (module lattices) and has undergone rigorous scrutiny during the NIST PQC standardization process.
- **Performance:** While having larger signature sizes than ECDSA, ML-DSA offers fast signature generation and verification, a critical feature for both the manufacturer signing the firmware and the resource-constrained device verifying it during an OTA update.

Real-World Applicability: Securing the Smart Grid

Consider the smart grid, which relies on millions of connected sensors and actuators. A compromised OTA update could disrupt power for millions. Using ML-DSA to sign firmware updates ensures that control commands and software patches come from a legitimate source and haven't been tampered with, hardening this critical infrastructure against future quantum threats and sophisticated present-day attackers.

Comparison: Classical vs. ML-DSA Signatures

Metric	ECDSA (P-256)	RSA (2048-bit)	ML-DSA-44
NIST Security Level	1 (Classical)	1 (Classical)	2 (Quantum-Resistant)
Public Key Size	~64 bytes	~256 bytes	~1312 bytes
Signature Size	~72 bytes	~256 bytes	~2420 bytes
Verification Speed	Slow	Very Fast	Fast
Quantum Resistance	**No**	**No**	**Yes**

Note: Sizes are approximate. ML-DSA-44 is the CRYSTALS-Dilithium variant targeting NIST Level 2 security. The main trade-off is the larger key and signature sizes, which require careful consideration in constrained environments.

Daily Quiz

1. What is the primary motivation for using ML-DSA for firmware signing instead of continuing with ECDSA?
2. What is the main implementation challenge when deploying ML-DSA on resource-constrained IoT devices?
3. Explain the concept of a "Harvest Now, Decrypt Later" attack in the context of OTA updates.
